

DATA PROCESSING AGREEMENT

PARTIES

Controller: [CONTROLLER COMPANY NAME]

Processor: ProductOS

Effective Date: [DATE]

SECTION I

GENERAL PROVISIONS

1. PURPOSE AND SCOPE

1.1 This Data Processing Agreement ("**Agreement**") is concluded pursuant to Articles 28(3) and (4) of Regulation (EU) 2016/679 ("**GDPR**") and incorporates AI governance requirements under Regulation (EU) 2024/1689 ("**EU AI Act**").

1.2 This Agreement establishes binding data protection obligations for the processing of personal data through ProductOS's AI-native product management platform.

1.3 These clauses apply exclusively to the processing activities, data categories, and purposes specified in **Annex II**.

1.4 All Annexes are legally binding and form an integral part of this Agreement.

1.5 This Agreement supersedes any conflicting data processing terms in other agreements between the parties.

2. IMMUTABILITY AND AMENDMENT

2.1 These Standard Contractual Clauses shall not be modified except:

- (a) To update factual information in Annexes I and IV upon 30 days' written notice;
- (b) To enhance data protection safeguards with both parties' written consent;

- (c) To comply with mandatory legal requirements.

2.2 Any modifications must maintain or strengthen the level of data protection provided herein.

3. INTERPRETATION AND HIERARCHY

3.1 Terms defined in the GDPR and EU AI Act have the same meaning in this Agreement.

3.2 In case of conflict, the following hierarchy applies:

1. GDPR and EU AI Act mandatory provisions
2. These Standard Contractual Clauses
3. Annexes to this Agreement
4. Other contractual provisions

4. THIRD-PARTY BENEFICIARIES

4.1 Data subjects are third-party beneficiaries of this Agreement and may enforce their rights directly against the Processor.

4.2 Supervisory authorities may enforce this Agreement on behalf of data subjects.

SECTION II

OBLIGATIONS OF THE PARTIES

5. PROCESSING SPECIFICATIONS

5.1 Personal data processing is strictly limited to:

- (a) The specific purposes enumerated in **Annex II, Section C**;
- (b) The data categories listed in **Annex II, Section B**;
- (c) The retention periods specified in **Annex II, Section D**.

5.2 Any processing outside these parameters requires a formal written amendment to this Agreement.

6. CONTROLLER OBLIGATIONS

6.1 Legal Basis and Instructions

(a) The Controller represents that it has established a valid legal basis under Article 6 GDPR for all processing activities specified herein.

(b) Processing instructions are documented in **Annex II** and may only be modified through written amendment.

(c) The Controller shall immediately notify the Processor of any withdrawal of consent, objections to processing, or changes to legal basis.

6.2 Data Quality and Minimization

(a) The Controller ensures that personal data provided is:

- Accurate and up-to-date
- Limited to what is necessary for specified purposes
- Obtained lawfully and transparently

(b) The Controller shall promptly correct inaccurate data and delete data no longer necessary for the specified purposes.

7. PROCESSOR OBLIGATIONS

7.1 Processing Restrictions

(a) The Processor shall process personal data **only**:

- On documented Controller instructions as specified in **Annex II**
- For the explicit purposes listed in **Annex II, Section C**
- During the authorized processing periods in **Annex II, Section D**

(b) **PROHIBITED PROCESSING:**

- Training general-purpose AI models using personal data
- Creating individual behavioral profiles for commercial purposes unrelated to specified services
- Automated decision-making affecting individuals without explicit safeguards
- Cross-border transfers without adequate safeguards
- Secondary use for any purpose not explicitly authorized

7.2 AI-Specific Processing Safeguards

(a) **Algorithmic Transparency Requirements:**

- All AI systems processing personal data must maintain explainable outputs
- Decision logic must be documented and auditable
- Algorithm changes affecting personal data processing require Controller notification

(b) Human Oversight Mandatory:

- Meaningful human review required for all AI-generated recommendations affecting individuals
- Human intervention mechanism available for all automated decisions
- Override capability maintained for all AI system outputs

(c) Bias Prevention and Monitoring:

- Regular bias testing of AI models processing personal data
- Fairness metrics monitoring for demographic groups
- Quarterly bias assessment reports provided to Controller

(d) AI Training Data Governance:

- Personal data used only for Controller-specific model optimization
- No inclusion in foundational model training datasets
- Synthetic data preferred for model improvement where possible

7.3 Enhanced Security Measures

(a) State-of-the-Art Technical Safeguards:

- AES-256 encryption at rest with annual key rotation
- TLS 1.3 minimum with certificate pinning for data in transit
- Hardware Security Modules (HSM) for key management in EU jurisdiction
- Zero-trust network architecture implementation
- End-to-end encryption for sensitive data categories

(b) Access Control Framework:

- Multi-factor authentication mandatory for all access
- Role-based access with principle of least privilege
- Privileged access management (PAM) with session recording
- Geographic access restrictions for non-EU locations
- Automated session timeout (maximum 8 hours)
- Failed login lockout after 3 attempts

(c) Monitoring and Detection:

- 24/7 Security Operations Center (SOC) monitoring
- Automated threat detection and response (SOAR)
- Real-time anomaly detection for data access patterns
- Continuous vulnerability scanning and management
- Intrusion detection and prevention systems (IDS/IPS)

7.4 Confidentiality and Staff Training

(a) All personnel with access to personal data must:

- Sign legally binding confidentiality agreements
- Complete GDPR and data protection training annually
- Undergo background security clearance checks
- Acknowledge personal liability for data protection violations

(b) Access privileges are reviewed quarterly and immediately revoked upon role change or termination.

8. DATA SUBJECT RIGHTS IMPLEMENTATION

8.1 Mandatory Response Framework

Right	Maximum Response Time	Implementation
Access (Art. 15)	15 business days	Automated data export system
Rectification (Art. 16)	5 business days	Real-time data correction interface
Erasure (Art. 17)	10 business days	Secure multi-pass deletion
Restriction (Art. 18)	5 business days	Processing suspension capability
Portability (Art. 20)	15 business days	Machine-readable format export
Objection (Art. 21)	Immediate	Automated processing cessation

8.2 Automated Decision-Making Safeguards (Article 22)

(a) **Prohibition on Fully Automated Decisions:** No solely automated processing with legal or significant effects without:

- Explicit Controller authorization in writing
- Meaningful human intervention capability
- Explanation mechanism for decision logic
- Right to challenge and request human review

(b) **Profiling Restrictions:**

- Individual profiling only for explicitly authorized purposes
- Transparent profiling logic with explanation capability
- Opt-out mechanism for non-essential profiling

- Regular accuracy and fairness assessments

8.3 Assistance Obligations

(a) The Processor shall provide technical assistance within **48 hours** for all data subject requests.

(b) Data Protection Impact Assessments: The Processor shall assist with DPIA requirements, providing:

- Processing operation documentation
- Risk assessment data
- Mitigation measure descriptions
- Technical specification details

9. STRICT SUB-PROCESSOR GOVERNANCE

9.1 Authorization Requirements

(a) Pre-Approved Sub-processors Only: Processing limited to entities listed in **Annex IV** with explicit security and privacy certifications.

(b) New Sub-processor Approval Process:

- 45 days advance written notice to Controller
- Detailed security assessment provided
- Draft sub-processor agreement shared
- Controller consent required before engagement
- 30-day objection period with detailed reasoning rights

9.2 Sub-processor Contractual Requirements

(a) Mandatory Contractual Provisions:

- Identical data protection obligations as this Agreement
- Direct audit rights for Controller
- Immediate termination rights for non-compliance
- Joint and several liability for GDPR violations
- Mandatory data breach notification within 2 hours
- Prohibited further sub-contracting without authorization

(b) Enhanced Due Diligence:

- Annual security audits (SOC 2 Type II minimum)
- Quarterly compliance reporting
- Real-time breach notification integration

- Continuous security monitoring access

9.3 Geographic and Jurisdictional Controls

(a) EU Processing Preference: Sub-processors in EU/EEA jurisdictions prioritized.

(b) Third Country Restrictions:

- Processing in third countries only with Controller consent
- Adequacy decision or Standard Contractual Clauses mandatory
- Transfer Impact Assessment required (Schrems II compliance)
- Government access disclosure procedures specified
- Data localization options provided where technically feasible

10. INTERNATIONAL DATA TRANSFERS

10.1 Transfer Safeguards Framework

(a) Prohibited Transfers: No transfers to countries without adequate data protection unless:

- European Commission adequacy decision exists, OR
- Standard Contractual Clauses implemented with supplementary measures, OR
- Specific Controller authorization with enhanced safeguards

(b) Supplementary Measures Required:

- Technical measures: end-to-end encryption, key management in EU
- Organizational measures: data access controls, government request procedures
- Contractual measures: enhanced liability, audit rights, termination triggers

10.2 Government Access and Surveillance

(a) Resistance and Notification Obligations:

- Legal challenge requirement for government data requests
- Immediate Controller notification unless legally prohibited
- Narrowest possible interpretation of legal obligations
- Transparency reporting on government requests (where permitted)

(b) Emergency Suspension: Transfers suspended if:

- Surveillance law changes compromise data protection
- Government access requests become systematic
- Adequate safeguards no longer maintainable

11. ENHANCED BREACH NOTIFICATION

11.1 Tiered Notification Framework

Breach Risk Level	Notification Time	Required Actions
High Risk	2 hours	Immediate cessation, forensic investigation
Medium Risk	12 hours	Risk assessment, containment measures
Low Risk	24 hours	Documentation, preventive measures

11.2 Detailed Notification Requirements

(a) Immediate Notification Contents:

- Breach detection timestamp and discovery method
- Data categories and approximate number of affected individuals
- Likely consequences and preliminary risk assessment
- Immediate containment measures implemented
- Preliminary cause analysis
- Contact information for further details

(b) Follow-up Reporting:

- 72-hour detailed forensic report
- Root cause analysis within 7 days
- Remediation plan within 14 days
- Final incident report within 30 days

11.3 Data Subject Notification Support

The Processor shall assist with direct data subject notifications by providing:

- Individual-level impact assessments
 - Recommended protective measures
 - Technical explanation of breach circumstances
 - Contact information for inquiries
-

SECTION III

COMPLIANCE AND ENFORCEMENT

12. AUDIT AND MONITORING RIGHTS

12.1 Controller Audit Authority

(a) Scheduled Audits: Annual on-site audits with 30 days' notice.

(b) Unscheduled Audits: Immediate audit rights upon:

- Suspected GDPR violations
- Security breaches affecting personal data
- Regulatory investigation initiation
- Changes to processing operations

(c) Audit Scope: Full access to:

- Processing systems and databases
- Security logs and monitoring data
- Staff interviews and documentation review
- Sub-processor facilities and records

12.2 Third-Party Audit Requirements

(a) Mandatory Certifications:

- ISO 27001 (Information Security Management)
- SOC 2 Type II (Security and Availability)
- ISO 27017 (Cloud Security)
- Annual penetration testing by certified providers

(b) Audit Report Sharing: Complete audit reports shared with Controller within 30 days of completion.

13. LIABILITY AND COMPENSATION

13.1 GDPR Violation Liability

(a) Joint and Several Liability: Both parties liable for GDPR violations within their respective responsibilities.

(b) Indemnification Framework:

- Processor indemnifies Controller for violations caused by Processor non-compliance
- Controller indemnifies Processor for violations caused by unlawful instructions
- Mutual indemnification for joint violations

13.2 Financial Safeguards

(a) Insurance Requirements: Processor maintains:

- Cyber liability insurance (minimum €50 million coverage)
- Professional indemnity insurance (minimum €25 million coverage)
- Data breach response insurance (minimum €10 million coverage)

(b) Penalty Allocation: GDPR administrative fines allocated based on:

- Proportional responsibility for violation
- Revenue-based calculation adjustment
- Cooperation level with authorities

14. TERMINATION AND DATA RETURN

14.1 Immediate Termination Triggers

(a) Material Breach Termination: Either party may terminate immediately upon:

- GDPR violation causing high risk to data subjects
- Security breach compromising personal data
- Unauthorized sub-processor engagement
- Failure to implement required technical measures
- Government access without adequate resistance

14.2 Data Return and Deletion Procedures

(a) Secure Data Return: Within 30 days of termination:

- Complete data return in agreed format
- Verified deletion from all systems (including backups)
- Deletion certificates from all sub-processors
- Final security audit of deletion process

(b) Legal Hold Exceptions: Data retention only permitted when:

- Explicit legal obligation exists
- Specific retention law applies
- Litigation hold requirements active
- Written Controller authorization provided

ANNEXES

ANNEX I - PARTIES

[Contact information and authorization details]

ANNEX II - DETAILED PROCESSING DESCRIPTION

A. CATEGORIES OF DATA SUBJECTS

- **Primary Users:** Enterprise product managers, product team members, system administrators
- **Secondary Users:** Stakeholders accessing shared product data and analytics
- **Indirect Subjects:** Individuals mentioned in product documentation and communications

B. SPECIFIC PERSONAL DATA CATEGORIES

B.1 Essential Account Data (*Legal Basis: Contract Performance - Art. 6(1)(b)*)

- **Identity Data:** Full names, email addresses, user identifiers
- **Professional Data:** Job titles, department, company affiliation, professional contact information
- **Authentication Data:** Password hashes, multi-factor authentication tokens, session identifiers
- **Retention:** Duration of contract + 12 months

B.2 Product Management Content (*Legal Basis: Contract Performance - Art. 6(1)(b)*)

- **Strategic Documents:** Product roadmaps, strategy documents, decision records
- **Project Data:** Task assignments, progress tracking, milestone documentation
- **Communication Records:** Meeting notes, decision rationales, stakeholder communications
- **Collaboration Content:** Shared documents, comments, version histories
- **Retention:** Duration of contract + 24 months (or as instructed by Controller)

B.3 Technical and Usage Data (*Legal Basis: Legitimate Interest - Art. 6(1)(f)*)

- **System Logs:** Access logs, error logs, performance metrics, security events
- **Usage Analytics:** Feature utilization, session duration, user interaction patterns
- **Technical Metadata:** IP addresses, device information, browser data, API usage logs
- **Integration Data:** Third-party tool synchronization logs, data mapping records
- **Retention:** 18 months maximum

B.4 AI Processing Data (*Legal Basis: Legitimate Interest - Art. 6(1)(f) with Enhanced Safeguards*)

- **Behavioral Patterns:** User interaction sequences for interface optimization
- **Content Analysis:** Text analysis of product documents for categorization and recommendations
- **Decision Support Data:** Historical decision patterns for recommendation algorithms
- **Retention:** 12 months maximum with anonymization after 6 months

C. SPECIFIC PROCESSING PURPOSES

C.1 Core Platform Services (*Art. 6(1)(b) - Contract Performance*)

1. **User Authentication and Access Management**
2. **Product Decision Centralization and Coordination**
3. **Cross-tool Data Integration and Synchronization**
4. **Document and Content Management**
5. **Collaboration and Communication Facilitation**

C.2 AI-Enhanced Services (*Art. 6(1)(f) - Legitimate Interest with Balancing Test*)

1. **Product Strategy Recommendations** (*Human oversight required*)
2. **Decision Pattern Analysis** (*Aggregated insights only*)
3. **Content Categorization and Search** (*No individual profiling*)
4. **Process Optimization Suggestions** (*Team-level recommendations*)

C.3 System Operations (*Art. 6(1)(f) - Legitimate Interest*)

1. **Security Monitoring and Threat Detection**
2. **Performance Optimization and System Monitoring**
3. **Error Detection and System Reliability**
4. **Compliance Monitoring and Audit Support**

C.4 Prohibited Purposes

-  Individual behavioral profiling for commercial purposes
-  Training general-purpose AI models with personal data
-  Marketing or advertising to individuals
-  Selling or sharing data with third parties for their purposes
-  Automated decision-making with legal effects without human oversight

D. RETENTION AND DELETION SCHEDULE

Data Category	Active Retention	Backup Retention	Deletion Method
Account Data	Contract duration + 12 months	+6 months	Multi-pass secure deletion

Product Content	As instructed by Controller	+24 months	Cryptographic erasure
Technical Logs	18 months	No backup retention	Automated purging
AI Training Data	12 months	No backup retention	Immediate secure deletion

E. GEOGRAPHIC PROCESSING LOCATIONS

Primary Processing: European Union (Ireland, Germany, Netherlands)

Restricted Processing:

- **United States:** Only with adequacy framework or SCCs + supplementary measures
 - **United Kingdom:** With UK adequacy decision and enhanced monitoring
 - **Other Jurisdictions:** Prohibited without explicit Controller authorization
-

ANNEX III - ENHANCED TECHNICAL AND ORGANIZATIONAL MEASURES

A. GOVERNANCE STRUCTURE

A.1 Data Protection Organization

- **Chief Data Protection Officer:** Direct regulatory authority communication
- **AI Ethics Board:** Monthly AI processing governance review
- **Security Response Team:** 24/7 incident response capability
- **Compliance Monitoring Team:** Continuous GDPR compliance assessment

A.2 Training and Awareness

- **Mandatory Training:** Annual GDPR, AI ethics, security awareness
- **Role-Specific Training:** Developer privacy engineering, support team data handling
- **Incident Response Training:** Quarterly breach response simulations
- **Certification Requirements:** Data protection certifications for key personnel

B. ADVANCED TECHNICAL SAFEGUARDS

B.1 Encryption and Key Management

- **Data at Rest:** AES-256 with customer-managed encryption keys (CMEK)
- **Data in Transit:** TLS 1.3 with certificate pinning and HSTS enforcement
- **Application-Level:** End-to-end encryption for sensitive document content
- **Key Rotation:** Automated quarterly rotation with HSM-based key generation
- **Key Geography:** All encryption keys stored and managed within EU jurisdiction

B.2 Access Control Matrix

SYSTEM_ACCESS:

Authentication:

- Multi-factor authentication (FIDO2 preferred)
- Hardware security keys for privileged access
- Biometric authentication for sensitive operations
- Certificate-based authentication for service accounts

Authorization:

- Attribute-based access control (ABAC)
- Just-in-time access provisioning
- Privileged access management with approval workflows
- Context-aware access decisions (location, time, risk)

Monitoring:

- Real-time access logging with SIEM integration
- Behavioral analytics for anomaly detection
- Privileged session recording and analysis
- Failed access attempt correlation and alerting

B.3 Data Protection by Design Implementation

- **Privacy Dashboard:** Real-time data processing visibility for Controllers
- **Consent Management:** Granular consent tracking and withdrawal mechanisms
- **Data Minimization Engine:** Automated identification of unnecessary data
- **Retention Automation:** Automatic data deletion based on retention schedules
- **Privacy Impact Assessment Tools:** Built-in DPIA workflow for processing changes

C. AI GOVERNANCE FRAMEWORK

C.1 Algorithm Accountability

AI_GOVERNANCE:

Explainability:

- Local interpretable model explanations (LIME) for all decisions

- Shapley value analysis for feature importance
- Counterfactual explanation generation
- Plain language explanation interface

Fairness:

- Demographic parity monitoring across protected groups
- Equalized odds assessment for decision accuracy
- Individual fairness testing with similarity metrics
- Bias mitigation algorithms in production pipelines

Human_Oversight:

- Mandatory human review for high-impact recommendations
- Human-in-the-loop validation for content categorization
- Override mechanisms with audit trails
- Escalation procedures for contested AI decisions

C.2 Model Lifecycle Management

- **Training Data Governance:** Synthetic data preferred, personal data minimization
- **Model Versioning:** Complete lineage tracking for all deployed models
- **Performance Monitoring:** Continuous accuracy and fairness drift detection
- **Update Procedures:** Impact assessment required for all model updates

D. INCIDENT RESPONSE PROCEDURES

D.1 Breach Detection and Classification

INCIDENT_CLASSIFICATION:

Critical_Severity:

- Unauthorized access to personal data
- Data exfiltration or theft
- System compromise affecting personal data
- Ransomware affecting personal data systems

High_Severity:

- Authorized access exceeding permissions
- Data corruption affecting personal data integrity
- Failed deletion procedures
- Sub-processor security incidents

Medium_Severity:

- Authentication system failures
- Monitoring system gaps
- Minor data retention violations
- Non-personal data security incidents

D.2 Escalation and Communication Framework

- **Internal Escalation:** Incident Commander → CISO → DPO → CEO (within 1 hour)
- **Controller Notification:** Immediate notification via secure channels
- **Authority Communication:** DPO manages all regulatory communications
- **Public Communication:** Pre-approved templates with legal review

ANNEX IV - CERTIFIED SUB-PROCESSORS

Entity	Service	Location	Certification	Data Scope	Safeguards
[Cloud Infrastructure Provider]	Infrastructure hosting	EU (Ireland)	ISO 27001, SOC 2 Type II	All categories (encrypted)	SCCs, CMEK, EU data residency
[Monitoring Service]	Security monitoring	EU (Germany)	ISO 27001, BSI C5	System logs, security events	SCCs, log anonymization
[Email Service Provider]	Notification delivery	EU (Netherlands)	ISO 27001, SOC 2 Type II	Contact information	SCCs, encryption in transit
[Backup Provider]	Encrypted backup storage	EU (France)	ISO 27001, HDS certification	Encrypted backup data	SCCs, client-side encryption

Sub-processor Security Requirements

- **Mandatory Certifications:** ISO 27001, SOC 2 Type II, relevant local standards
- **Audit Rights:** Controller may audit sub-processors directly with 14 days' notice
- **Incident Response:** Direct notification to Controller within 2 hours
- **Data Localization:** EU processing mandatory unless explicit Controller authorization
- **Contract Terms:** Identical data protection obligations with enhance

